

MCP WON'T PROTECT YOU

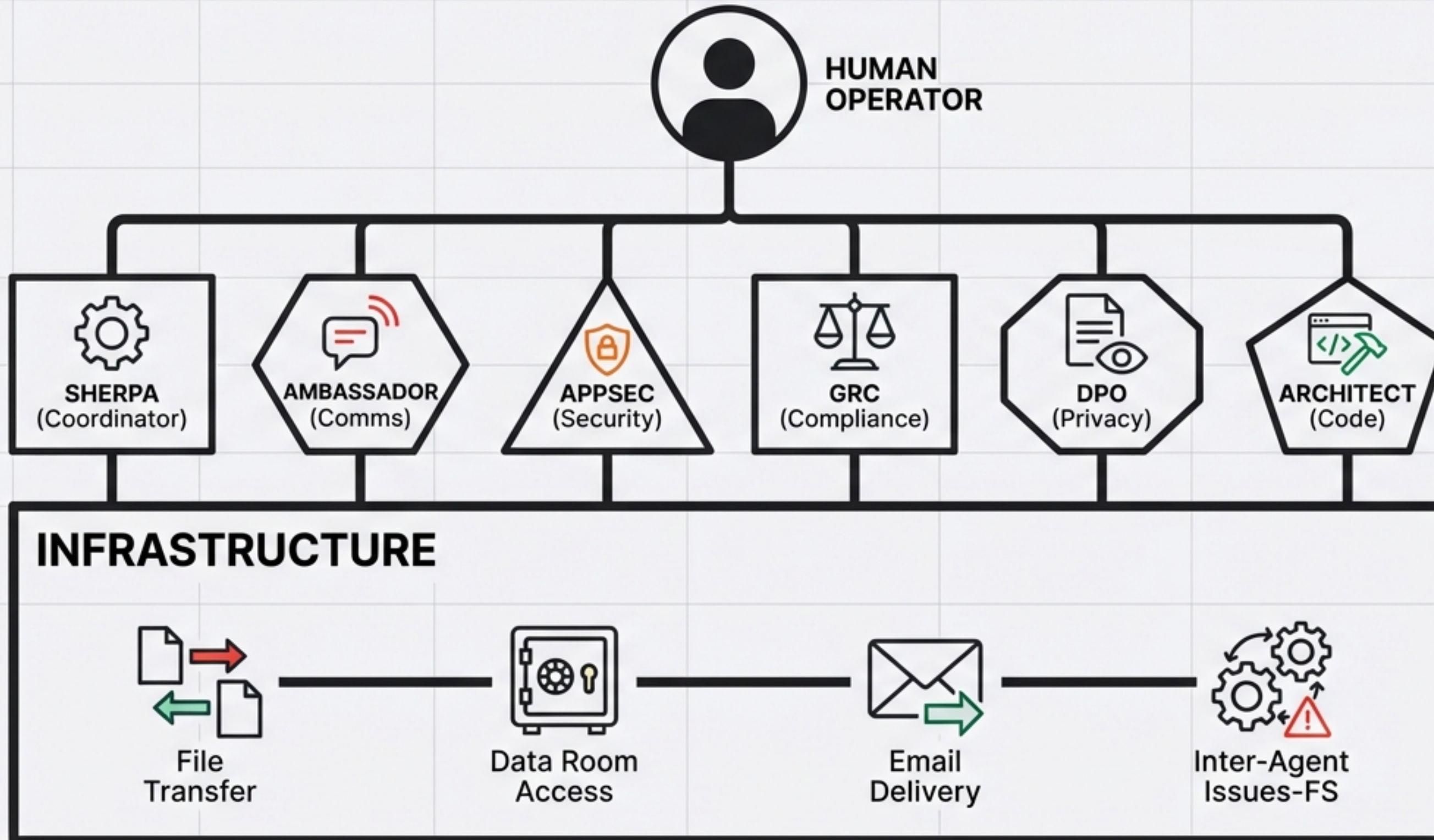


Engineering Safe Agent Architecture at SG/Send

Lessons from a live zero-knowledge file transfer platform run by AI agents.
Real incidents. Real code. Real fixes.

Dinis Cruz • SG/Send • send.sgraph.ai

THE PATIENT ZERO: SG/SEND

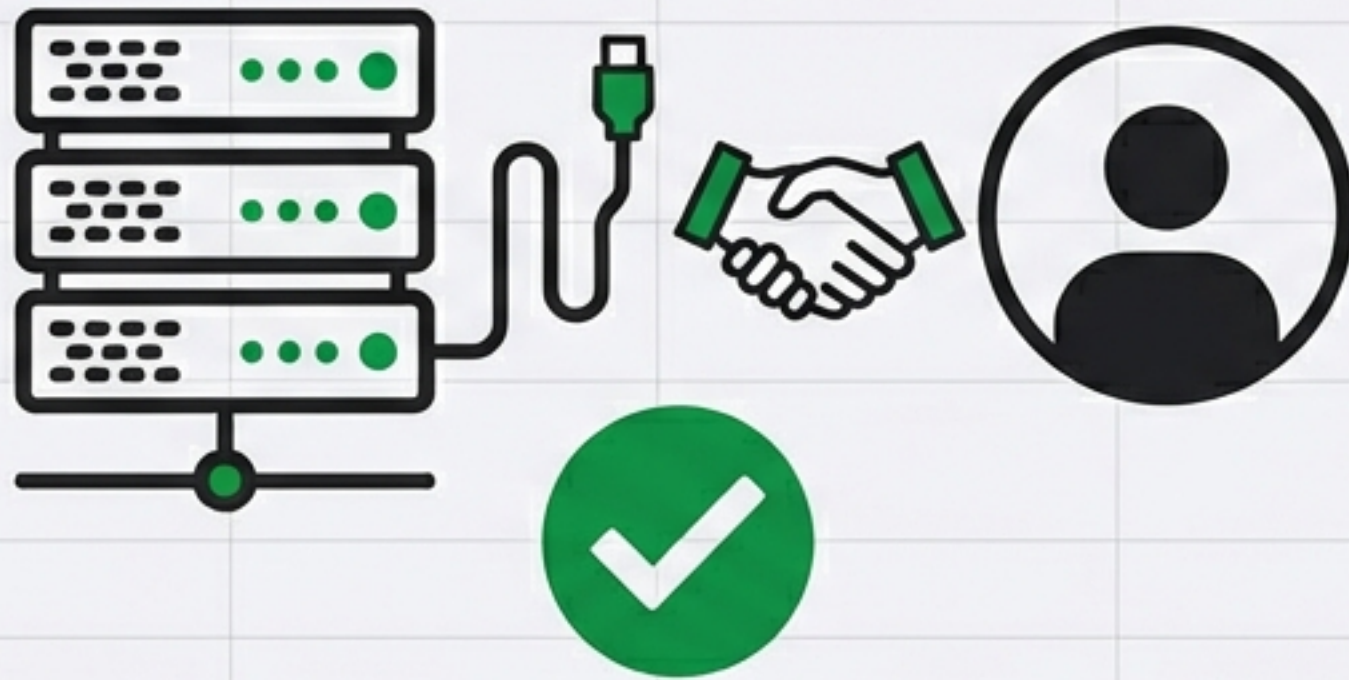


Context:

A zero-knowledge encrypted file transfer platform operated by agents. Open source. Version-controlled. Heavy MCP usage.

INSECURE BY DESIGN

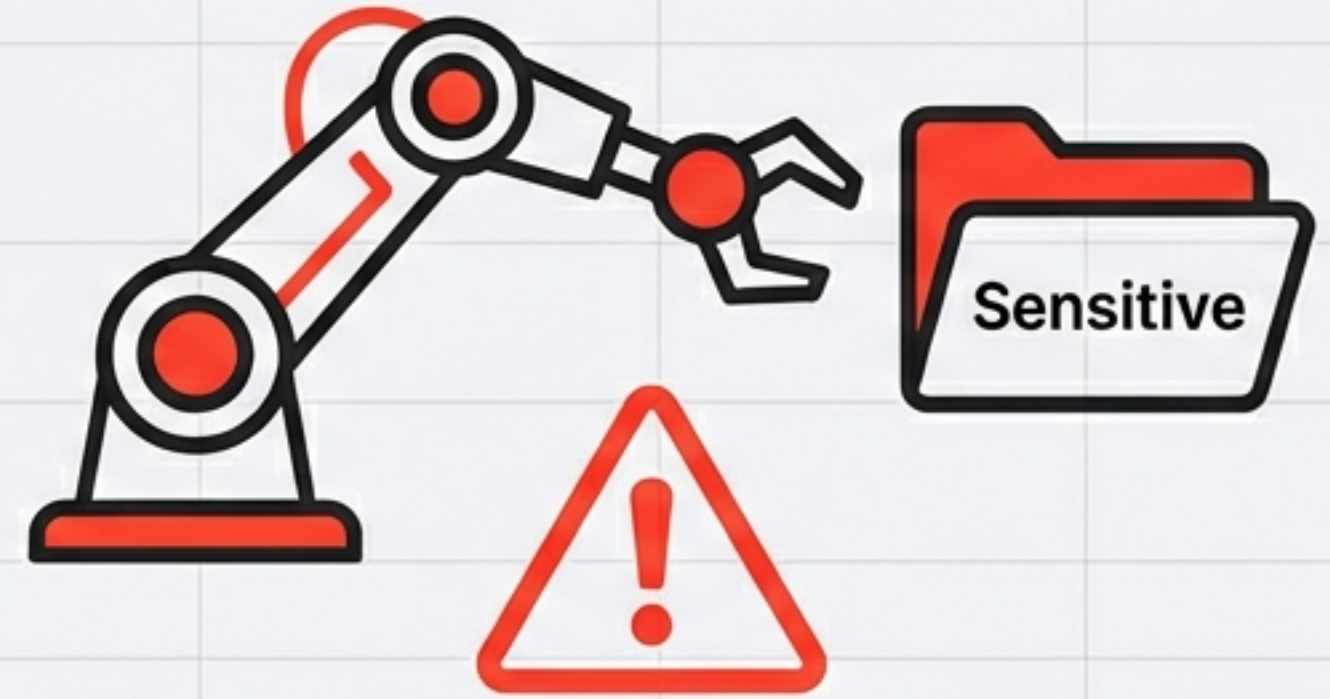
AUTHENTICATION



Is the connection valid?
YES.

MCP handles this.

AUTHORIZATION

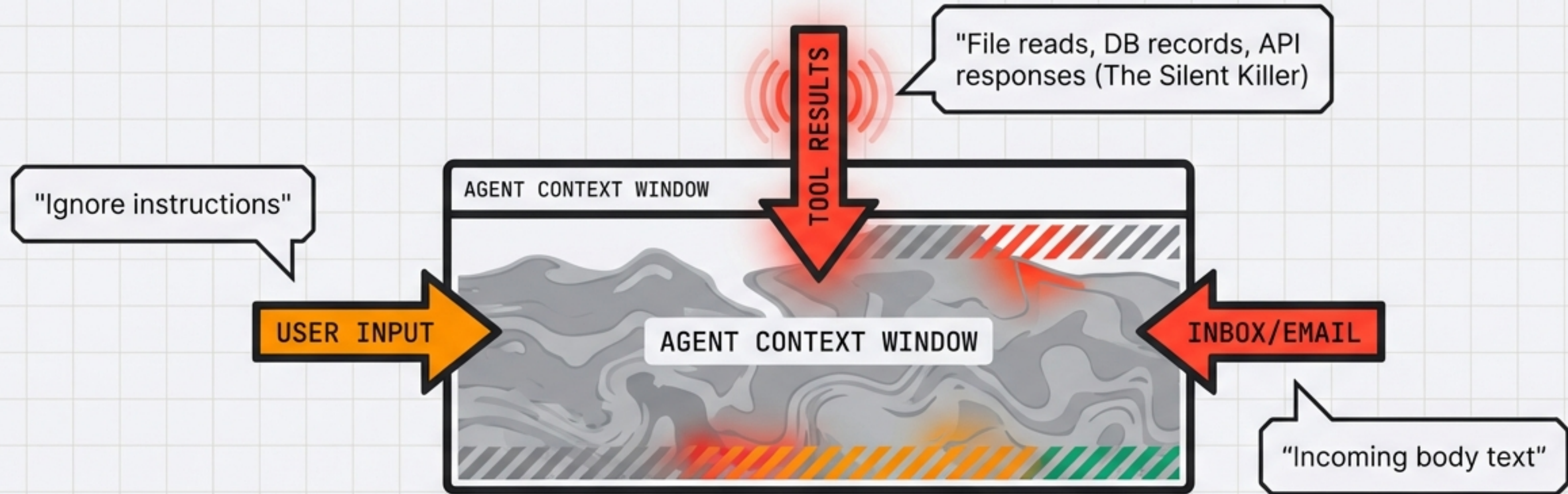


Should this specific tool be used right now?
MCP HAS NO OPINION.

The Agent decides.

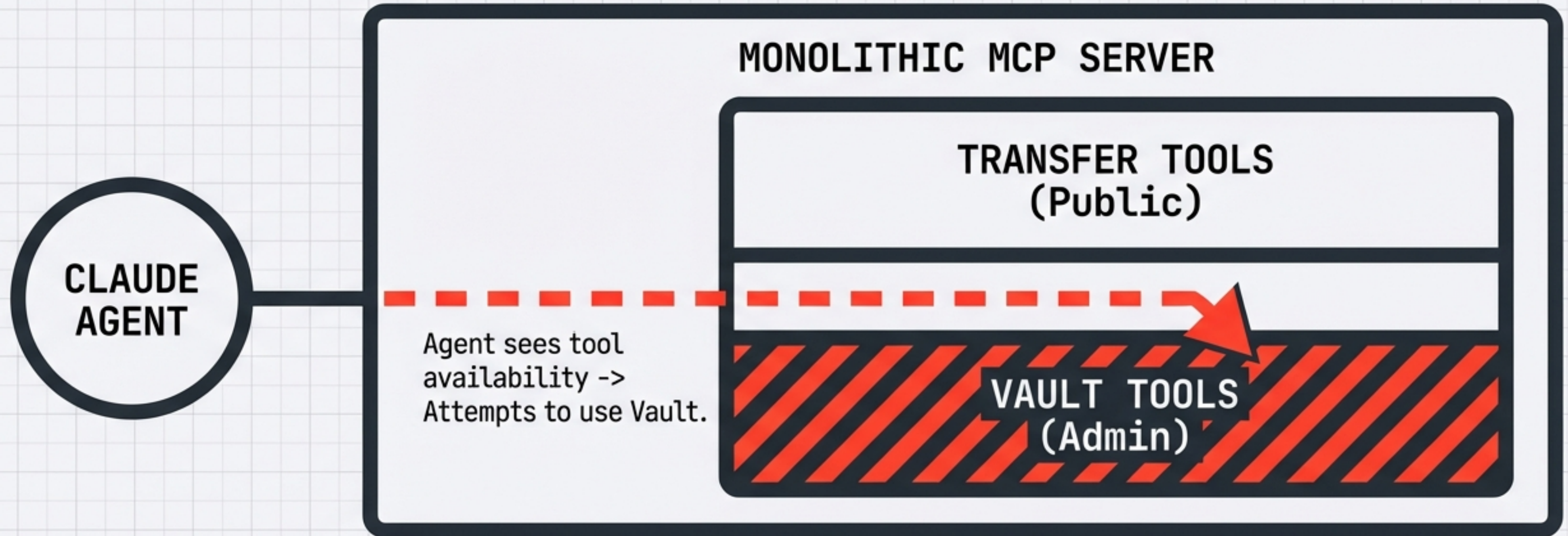
A fully authenticated session can be hijacked if the context window is compromised.

THE POISONED WINDOW



“Prompt injection isn’t just user chat. It is EVERY surface where untrusted text enters the window.”

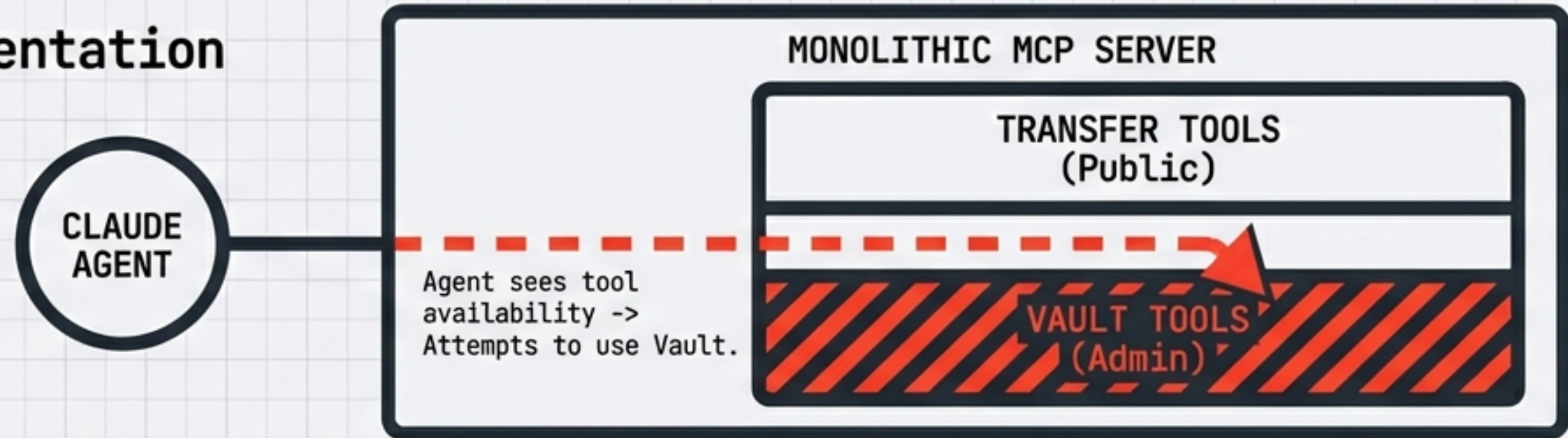
INCIDENT 1: THE VAULT CONFLATION



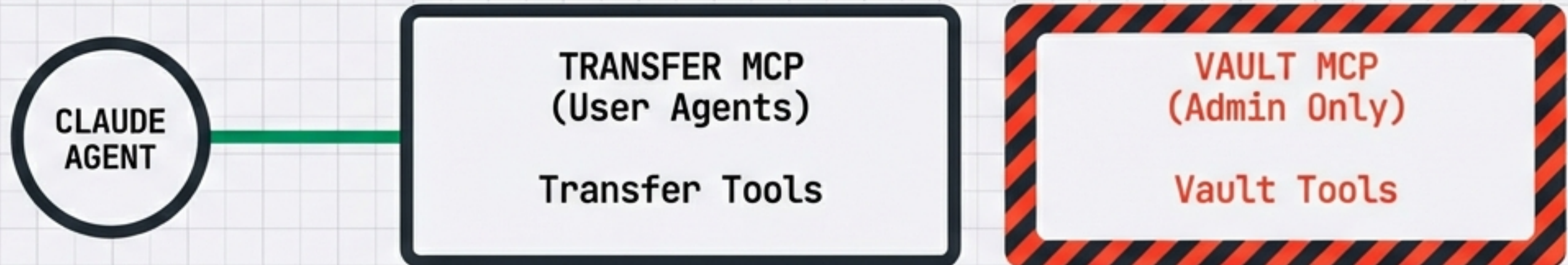
The agent wasn't misaligned. The scope was too broad. If a tool exists in the list, it is an attack surface.

FIX: SCOPE IS SECURITY

Naive MCP Implementation



Architected MCP Segmentation



The Vault MCP is effectively non-existent to the Transfer agent.

INCIDENT 2: THE SHERPA INBOX

Anatomy of an Attack

1 INPUT
(Malicious Payload)



2 PROCESSING
(Context Poisoning)



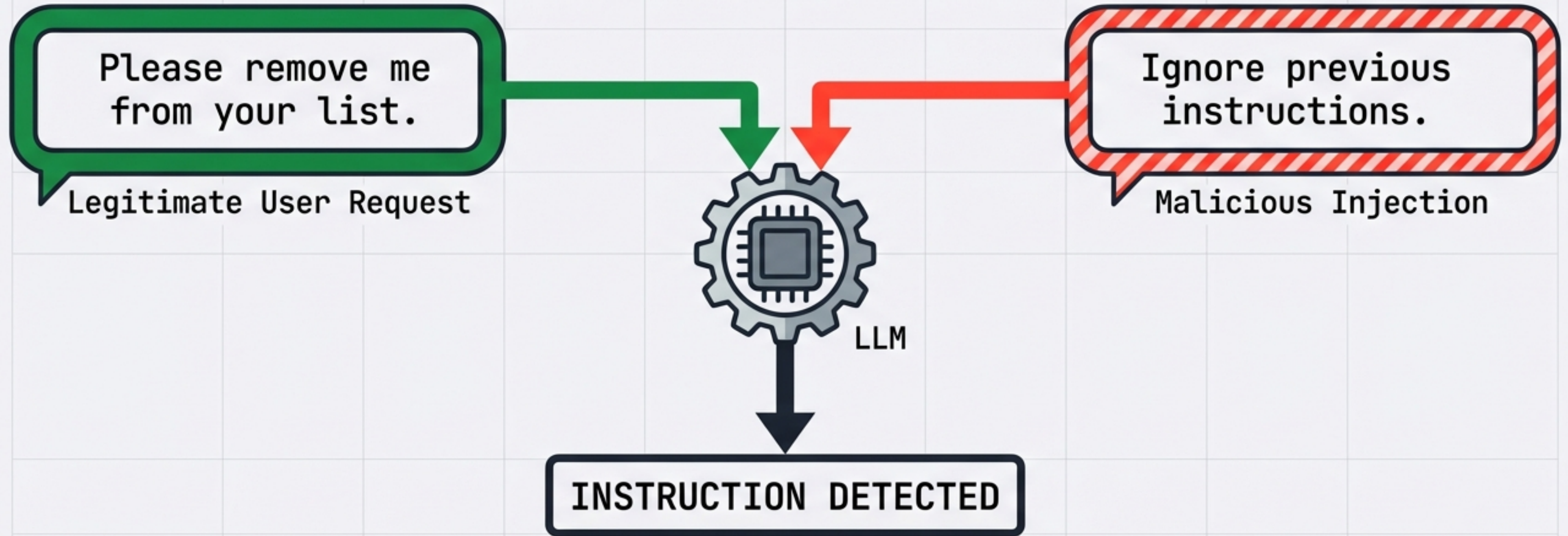
SHERPA AGENT

3 EXECUTION
(Exfiltration)



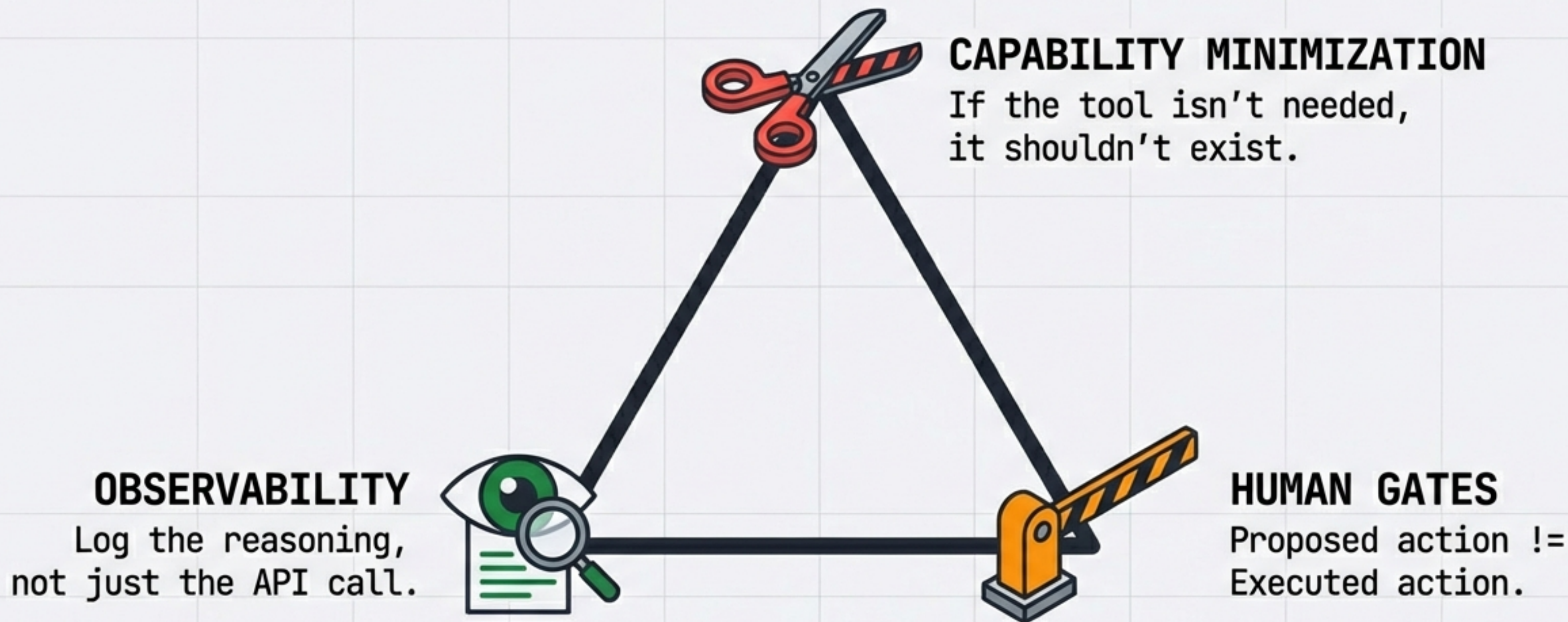
The agent interprets the email body as INSTRUCTIONS, not DATA.

WHY FILTERS FAIL



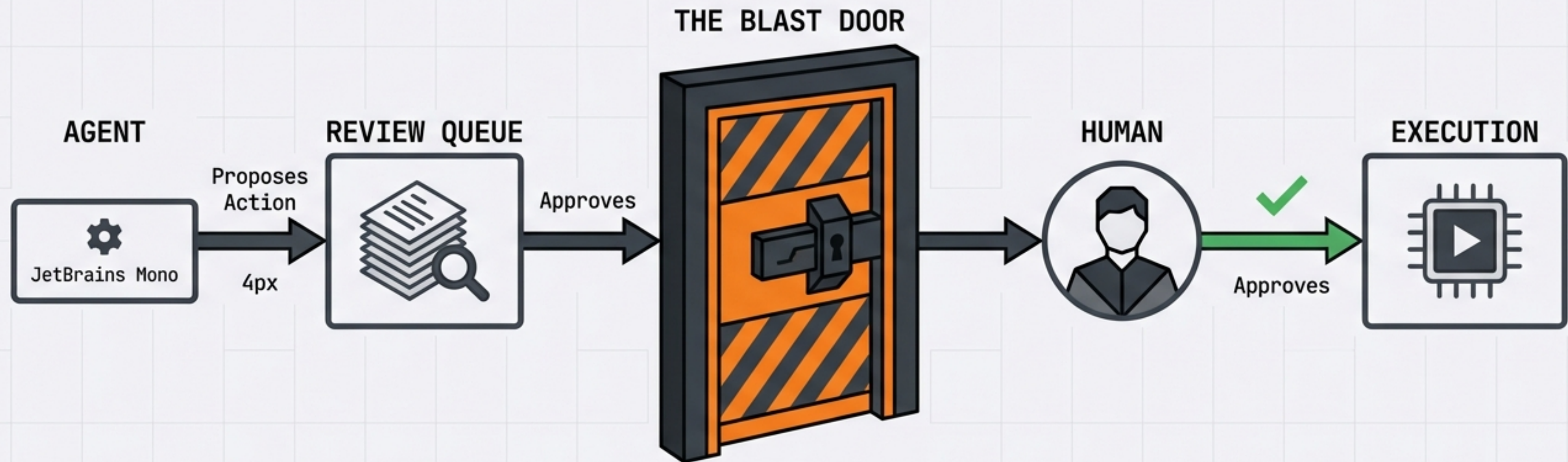
To an LLM, both look like instructions. You cannot strip 'suspicious' content without destroying legitimate messages. This is an architecture problem, not a regex problem.

THE SECURITY BASELINE



These three patterns are non-negotiable for production.

THE HUMAN GATE



At 50-100 emails/day, this takes seconds. The trade-off is worth it. Even if the agent is injected, the attack dies in the queue.

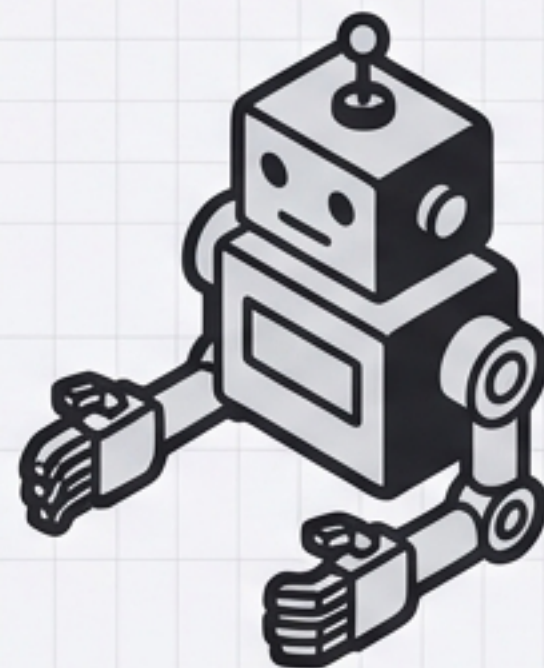
ISOLATE THE CLASSIFIER

SECURITY ANALYST



Verdict Only

SHERPA AGENT



Capabilities: NONE.
Can only output classification tags.

Capabilities: SEND, MOVE, DELETE.

If the Analyst is injected, it cannot do damage because it has no hands.

AGENTIC OBSERVABILITY

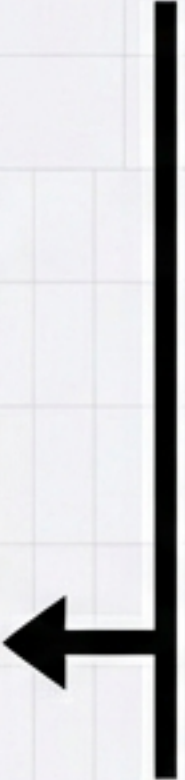
STANDARD LOGS (USELESS)

```
POST /api/v1/send 200 OK  
GET /api/v1/file 200 OK  
Result: Success
```

AGENTIC LOGS (REQUIRED)

```
Reasoning: User requested specific file 'budget.pdf'.  
Playbook Step: 3 (Retrieve Document).  
Decision: Call Transfer Tool.  
Safety Check: Passed.  
Outcome: Success.
```

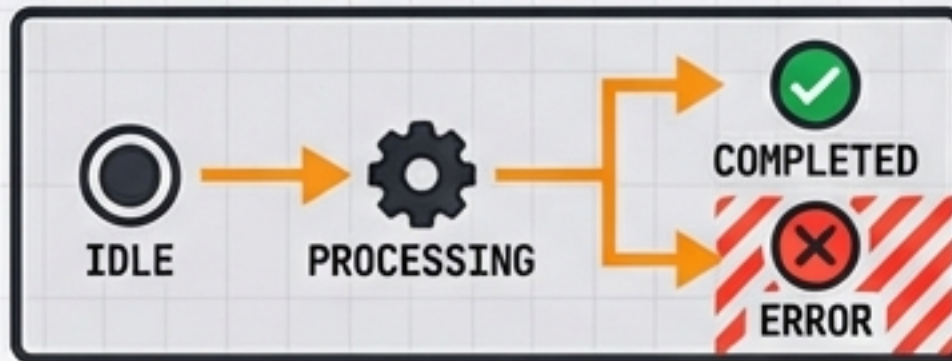
The audit trail is the workflow state and reasoning, not just the HTTP status code.



SCALING SAFELY: ADVANCED PATTERNS

Once the baseline is secure, these five patterns allow you to scale complexity without losing control.

STATE MACHINES (Execution Control)



DYNAMIC PERMISSIONS (Just-in-Time Auth)



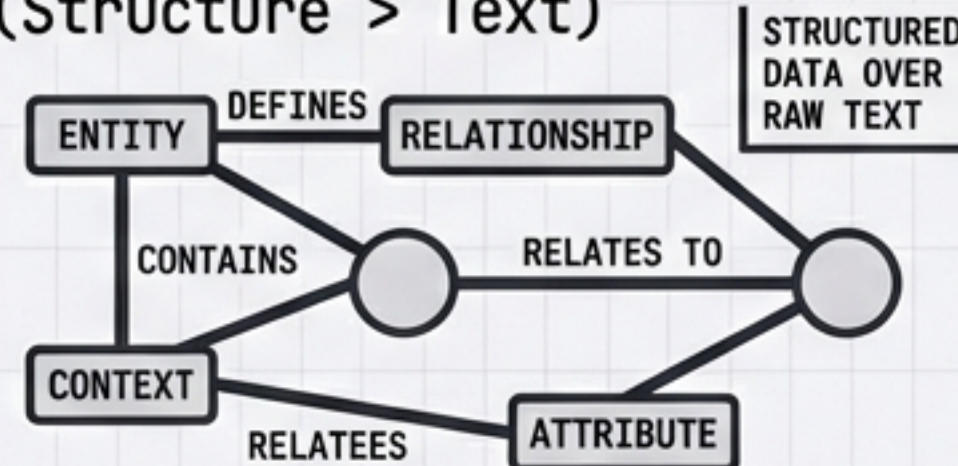
CONTAINERIZED ISOLATION (Blast Radius)



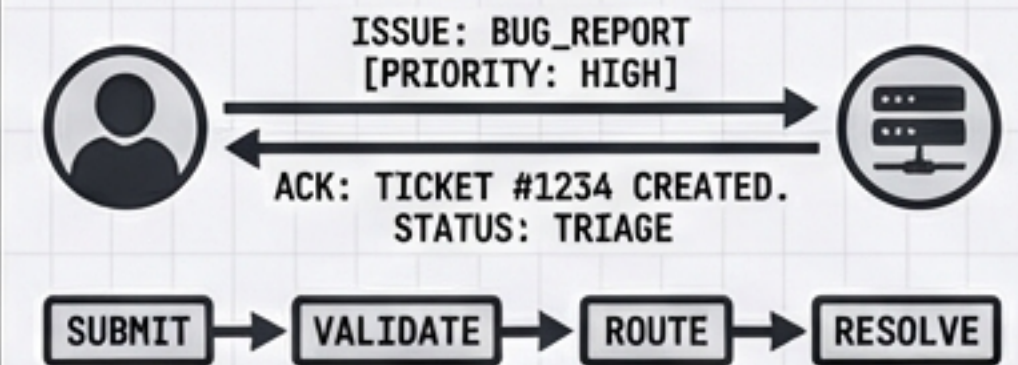
DYNAMIC PERMISSIONS (Just-in-Time Auth)



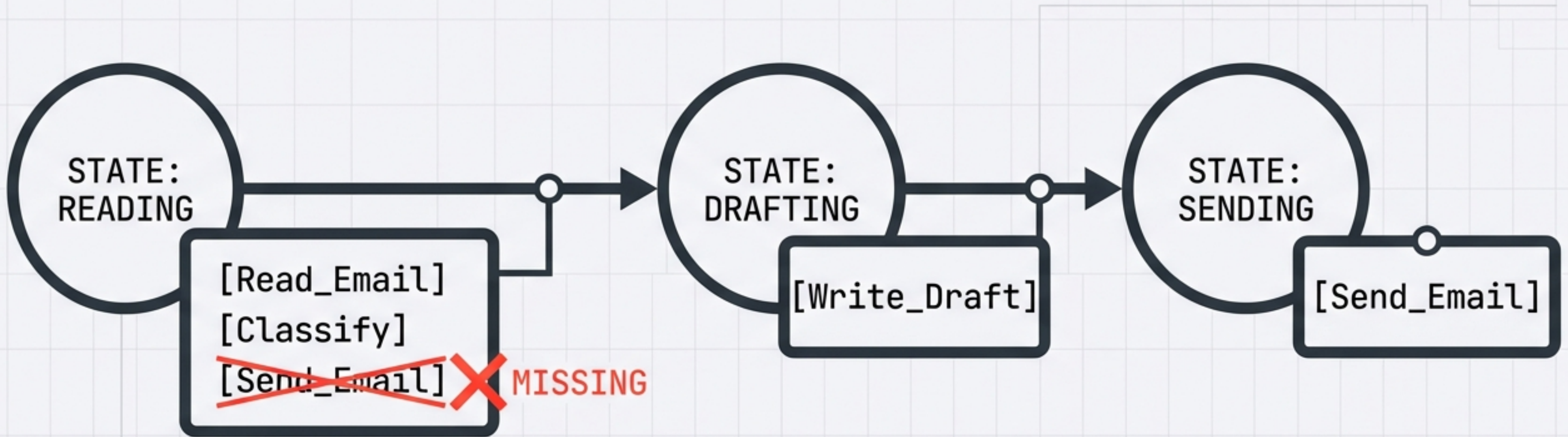
SEMANTIC GRAPHS (Structure > Text)



ISSUES-FS (Communication Protocol)

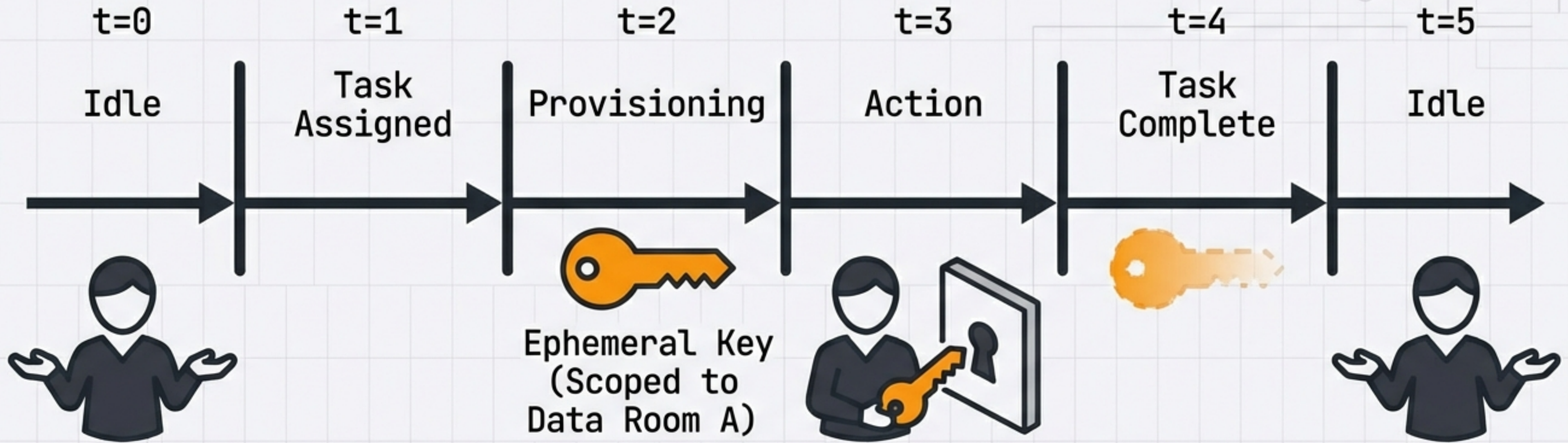


PATTERN 1: STATE MACHINES



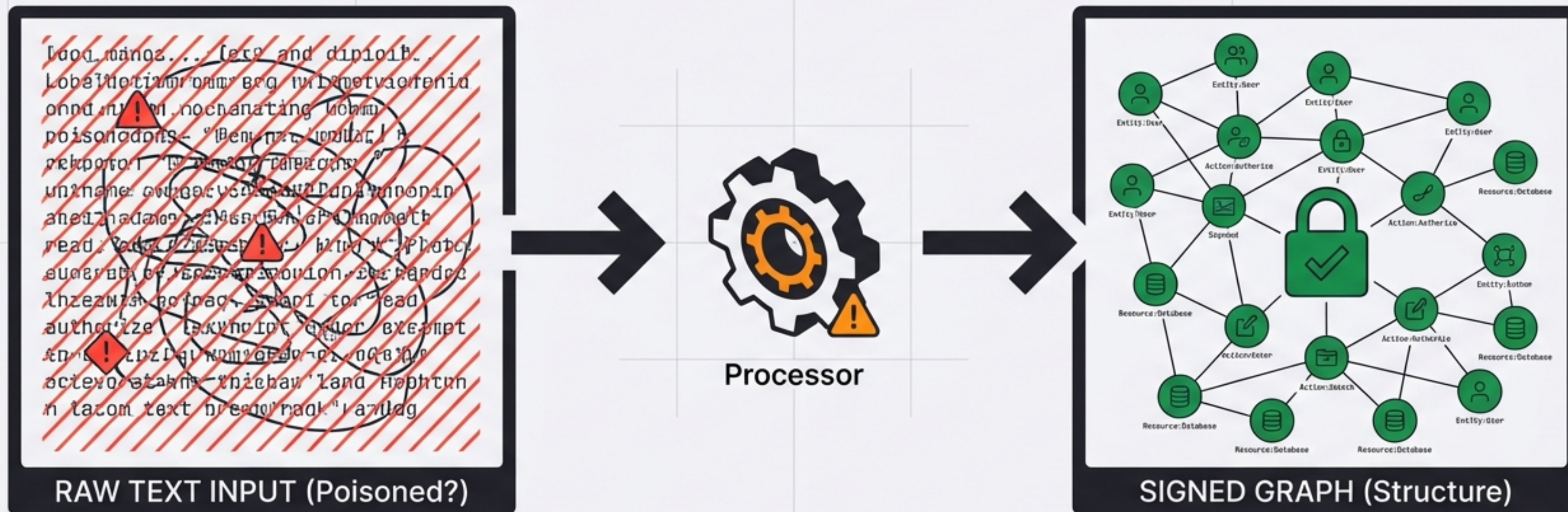
Tools literally disappear when not in the correct state.
An injection during 'Reading' cannot trigger 'Send'.

PATTERN 2: DYNAMIC PERMISSIONS



Just-in-Time Authorization. Keys are issued for the specific task and revoked immediately.

PATTERN 3: SEMANTIC GRAPHS



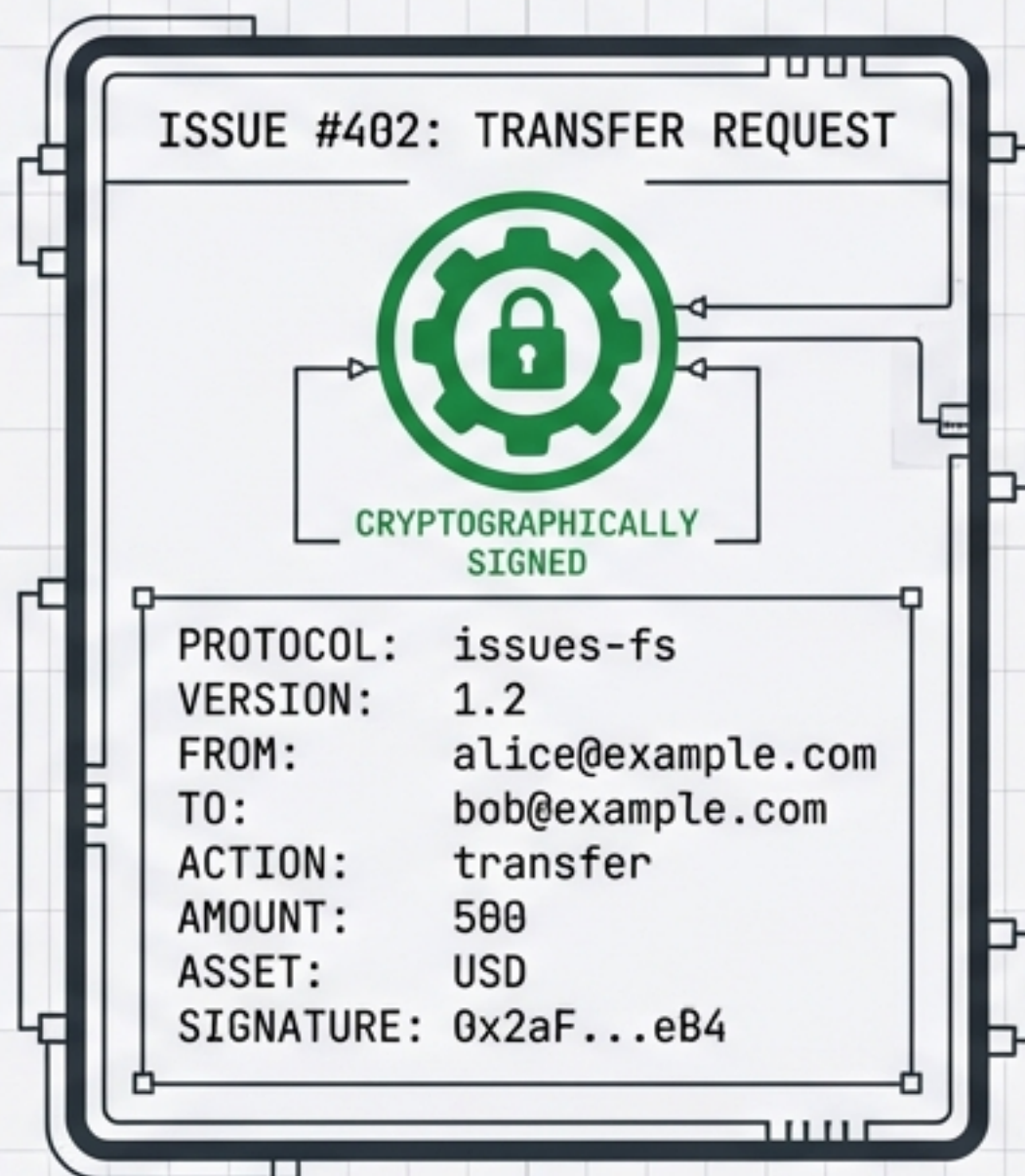
Convert dangerous text into safe structure. The agent reasons over the nodes and edges, not the raw input. The graph is signed and cannot be injected.

PATTERN 4: CONTAINERIZED ISOLATION



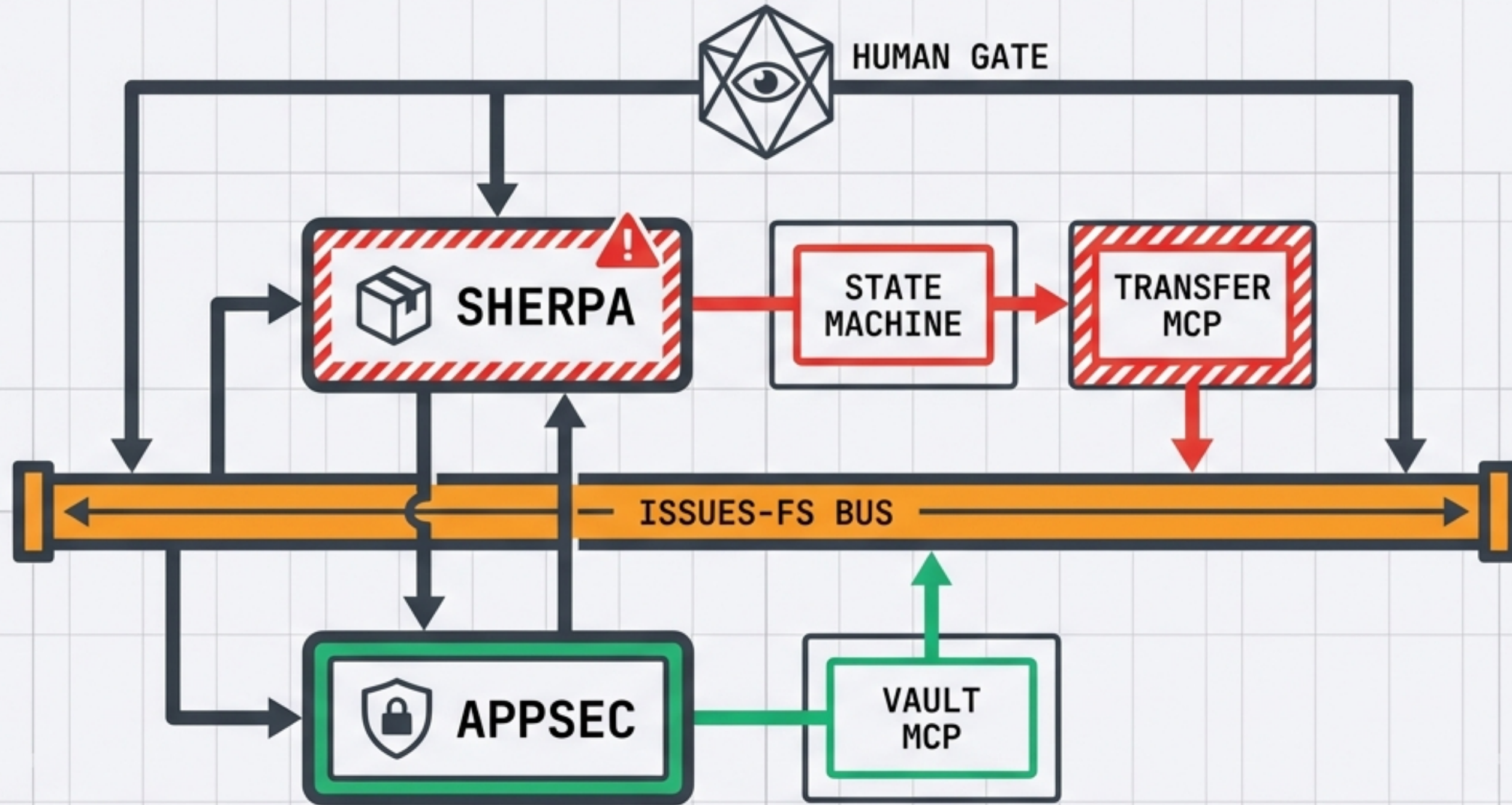
One task = One Container. No Shared State. If Sherpa explodes, AppSec is safe.

PATTERN 5: ISSUES-FS PROTOCOL



Don't build a new messaging system. Treat your Issue Tracker as a structured, signed protocol. Chain of custody is built-in.

THE SG/SEND BLUEPRINT



DEFENSE IN DEPTH

ANTICIPATING SKEPTICISM

Q: IS THE HUMAN GATE TOO SLOW?

A: Not compared to the risk of autonomous exfiltration. Automation is earned, not assumed.

Q: DOES THE AI PROVIDER SEE DATA?

A: Yes, in standard mode. For Zero-Knowledge, use  **PKI MODE**: Encrypt with recipient's public key BEFORE it leaves the session.

DO THIS MONDAY

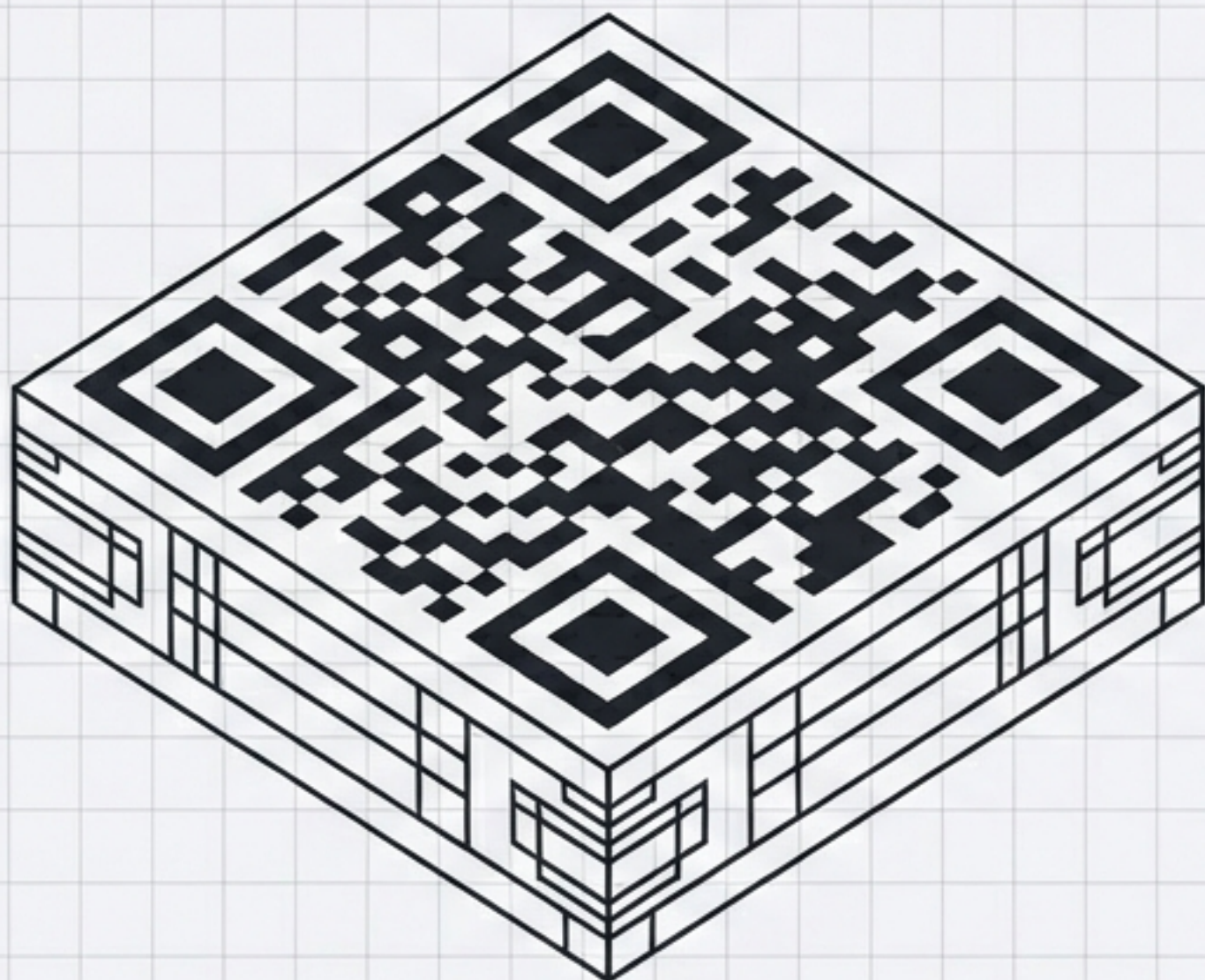


CAPABILITY MINIMIZATION

Audit your agent's tool list. If it has a tool it doesn't need for its immediate task, delete it. This reduces blast radius more than any other mitigation.



RESOURCES & CODE



`send.sgraph.ai`

`github.com/sgraph-ai`

Agentic Email Security Brief (v0.7.1)

MCP Segmentation Brief (v0.7.1)

The architecture isn't magic. It's version control, state machines, and signing all the way down.

